



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 1: مقدمة في السياسات الأمنية



دبلوم امن المعلومات

اسم المقرر:	السياسات والتشريعات والاخلاقيات والالتزام بها
رمز المقرر:	ISE123
الموضوع:	الفصل 1: مقدمة في السياسات الأمنية



يميز بين أنواع السياسات الأمنية وفق نطاقها والفئة المستهدفة.

يشرح مفهوم السياسة الأمنية ودورها في حماية المعلومات داخل المؤسسة.



يصيغ بنوداً أولية لسياسة استخدام مقبول لمؤسسة خدمية متوسطة.

يحلل مكونات سياسة أمن معلومات من حيث الغرض والنطاق والأدوار والالتزام.



يقترح خطوات تطوير وتنفيذ ومراجعة لسياسة أمن معلومات.





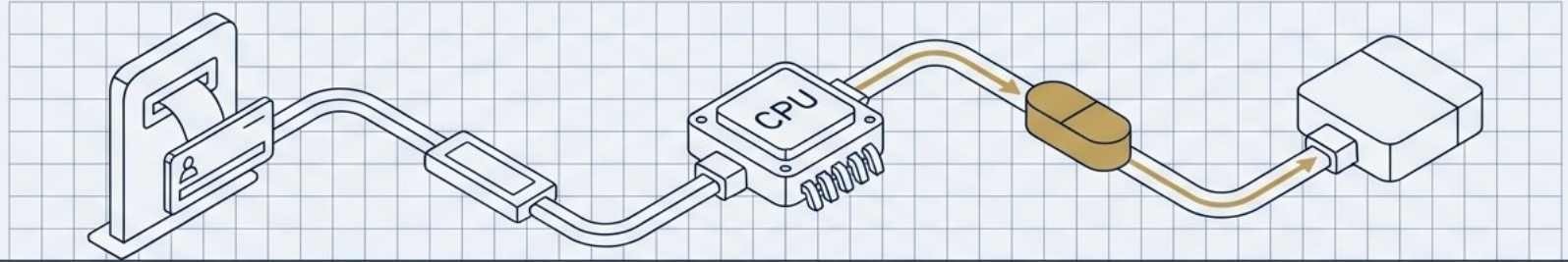
◀ يتناول الفصل المحاور الآتية:

1. السياسة الأمنية وعلاقتها بالحوكمة.
2. مكونات وثيقة سياسة أمن المعلومات.
3. أنواع السياسات الأمنية ومجالات تطبيقها.
4. دورة حياة السياسة، من الصياغة إلى المراجعة.
5. الاستثناءات والمخالفات والإجراء التصحيحي.
6. تحليل سياسة استخدام مقبول قابلة للتطبيق في مؤسسة سعودية.



SLIDE 3 · ELEMENT

خريطة الفصل



السياسة الأمنية
وعلاقتها بالحوكمة

دورة حياة السياسة، من
الصياغة إلى المراجعة

مكونات وثيقة سياسة
أمن المعلومات

الاستثناءات والمخالفات
والإجراء التصحيحي

أنواع السياسات الأمنية
ومجالات تطبيقها

تحليل سياسة استخدام
مقبول قابلة للتطبيق في
مؤسسة سعودية

يتناول الفصل المحاور الآتية:



الوحدة	خطوات التعلم والأدوات	المحتوى	الأنشطة	التقييم	المشروع	الإجمالي
1	قراءة المفهوم والهرم، ثم تحقق سريع	40	15	5	10	70
2	قراءة نموذج السياسة وتحليل المكونات والأدوار	40	15	10	5	70
3	مقارنة أنواع السياسات ووثائق الحوكمة	40	15	10	5	70
4	قراءة سجل المراجعة وبناء دورة الحياة	40	15	10	5	70



الوحدة	خطوات التعلم والأدوات	المحتوى	الأنشطة	التقييم	المشروع	الإجمالي
5	تحليل الاستثناء والمخالفة والإجراء التصحيحي	40	10	10	10	70
6	مثال محلول، صياغة بند، مراجعة واختبار	45	10	10	5	70
الإجمالي	قراءات ومستندات وأنشطة واختبارات ومرحلة المشروع	245	80	55	40	420 دقيقة

زمن الوحدة: 70 دقيقة.
ادرس المفهوم والهرم التنظيمي، ثم نفذ تحققاً سريعاً من الفرق بين السياسة والإجراء، وأنجز الجزء الأول من مرحلة المشروع.



- ◀ السياسة الأمنية هي قواعد تنظيمية موثقة تحكم حماية المعلومات واستخدامها ضمن مستوى مخاطرة مقبول.
- ◀ وظيفتها توجيه السلوك والقرارات والضوابط داخل المؤسسة، بدلاً من ترك الممارسة لاجتهاد الأفراد.
- ◀ **الوظيفة:** توحيد حماية الأصول المعلوماتية.
- ◀ **المسؤوليات:** تحديد الغرض، بيان سبب السياسة، تحديد النطاق، تعيين المشمولين، توزيع الأدوار، تحديد المساءلة، بيان الالتزام، توضيح المتطلبات، تنظيم المراجعة، متابعة الملاءمة.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ISO/IEC 27002:2022، NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة أو الأدوات:** وثيقة سياسة معتمدة، مستودع وثائق، سجل إصدار، سجل نشر وإقرار.
- ◀ **المخرج:** سياسة أمن معلومات معتمدة ومنشورة.
- ◀ **مثال:** تمثل POL-AUP-2026-017 سياسة استخدام مقبول تنظم حسابات وخدمات الشركة.



السياسة الأمنية (Security Policy) (الشكل)

SLIDE 5 • SECURITY POLICY

السياسة الأمنية

السياسة الأمنية هي قواعد تنظيمية موثقة تحكم حماية المعلومات واستخدامها ضمن مستوى مخاطرة مقبول. وظيفتها توجيه السلوك والقرارات والضوابط داخل المؤسسة، بدلاً من ترك الممارسة لاجتهاد الأفراد.



سياسة أمن معلومات معتمدة ومنشورة

الأجهزة والأدوات

- وثيقة سياسة معتمدة
- مستودع وثائق
- سجل إصدار
- سجل نشر وإقرار

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- توحيد حماية الأصول المعلوماتية
- تحديد الغرض
- بيان سبب السياسة
- تحديد النطاق
- تعيين المشمولين

تمثل POL-AUP-2026-017 سياسة استخدام مقبول تنظم حسابات وخدمات الشركة

السياسة الأمنية هي قواعد تنظيمية موثقة تحكم حماية المعلومات واستخدامها ضمن مستوى مخاطرة مقبول.



- ◀ الغرض من السياسة الأمنية بيان محدد يفسر الحاجة التنظيمية التي تعالجها الوثيقة وما الذي تسعى المؤسسة إلى حمايته أو تنظيمه.
- ◀ يمنع الغرض تحول السياسة إلى قائمة تعليمات بلا هدف.
- ◀ في الشركة، يربط غرض POL-AUP-2026-017 بين الاستخدام المشروع للمنصات التعليمية وحماية البيانات الشخصية واستمرارية الخدمة للمستخدمين.
- ◀ **الوظيفة:** ربط المتطلبات بالحاجة الأمنية.
- ◀ **المسؤوليات:** وصف الهدف، تحديد الأصول، ربط المخاطر، مراجعة الحاجة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022, NIST CSF 2.0.
- ◀ **الأدوات:** قالب سياسة، سجل مراجعات.
- ◀ **المخرج:** فقرة غرض واضحة.
- ◀ **مثال:** تنظيم الاستخدام الآمن للحسابات والخدمات الرقمية.



SLIDE 6 • ELEMENT

الغرض من السياسة الأمنية



فقرة غرض واضحة

المخرج المتوقع

- فقرة غرض واضحة

الأجهزة والأدوات

- قالب سياسة
- سجل مراجعات

الوظائف الرئيسية

- ربط المتطلبات بالحاجة الأمنية
- وصف الهدف
- تحديد الأصول
- ربط المخاطر
- مراجعة الحاجة

تنظيم الاستخدام الآمن للحسابات والخدمات الرقمية



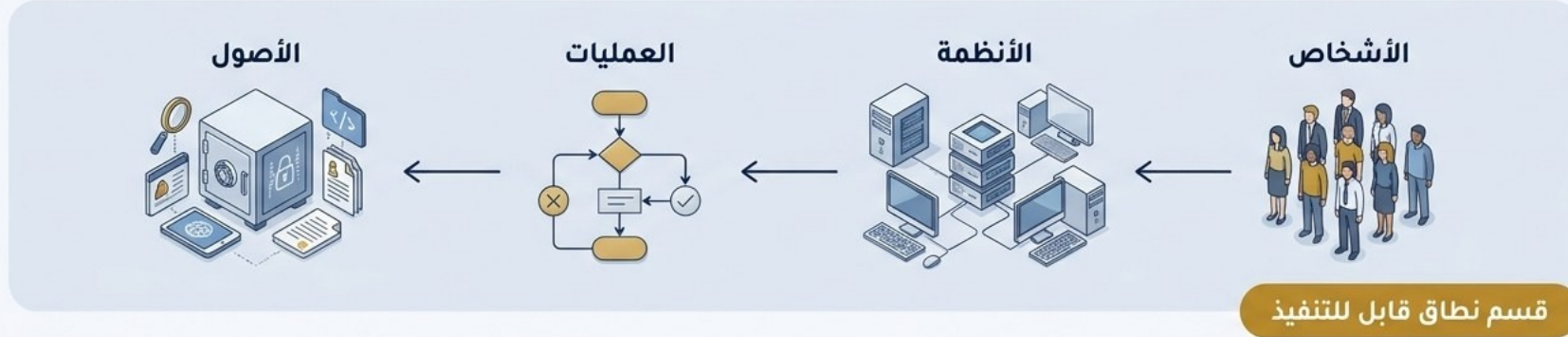
- ◀ نطاق السياسة الأمنية يحدد الأشخاص والأنظمة والعمليات والأصول التي تنطبق عليها الوثيقة.
- ◀ يبين النطاق حدود الالتزام، فلا يستخدم الموظف أو المتعاقد سياسة لا تخص دوره، ولا تستبعد خدمة مهمة بسبب صياغة عامة.
- ◀ يشمل نطاق سياسة الشركة الموظفين والمتعاقدين والمتدربين والمستفيدين المصرح لهم باستخدام البوابة والبريد والحسابات والأجهزة المتصلة بالخدمات.
- ◀ **الوظيفة:** تحديد حدود التطبيق والمساءلة.
- ◀ **المسؤوليات:** تحديد المشمولين، بيان الاستبعادات، مراجعة البيئة، تحديث الحدود.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022, NIST CSF 2.0.
- ◀ **الأدوات:** جدول نطاق، سجل أصول، قائمة أدوار.
- ◀ **المخرج:** قسم نطاق قابل للتنفيذ.
- ◀ **مثال:** تشمل السياسة الحسابات الرقمية للبوابة التعليمية فقط.



نطاق السياسة الأمنية (الشكل)

SLIDE 7 · ELEMENT

نطاق السياسة الأمنية



الأجهزة والأدوات

- جدول نطاق
- سجل أصول
- قائمة أدوار

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022
- NIST CSF 2.0

الوظائف الرئيسية

- تحديد حدود التطبيق والمساءلة
- تحديد المشمولين
- بيان الاستبعادات
- مراجعة البيئة
- تحديث الحدود

تشمل السياسة الحسابات الرقمية للبوابة التعليمية فقط.
نطاق السياسة الأمنية يحدد الأشخاص والأنظمة والعمليات والأصول التي تنطبق عليها الوثيقة.



نموذج سياسة استخدام مقبول

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
حازان- المملكة العربية السعودية
الرقم السري: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: سياسة الاستخدام المقبول للمنصات التعليمية والخدمات الرقمية

سياسة الاستخدام المقبول للمنصات التعليمية والخدمات الرقمية

معرف السياسة والإصدار: AUP-2026-017-POL، الإصدار 1.2

تاريخ الاعتماد: 2026-02-17

تاريخ النفاذ: 2026-03-01

مالك السياسة: إدارة الأمن السبراني

جهة الاعتماد: الإدارة التنفيذية

الغرض: تنظيم الاستخدام المشروع والأمن للمنصات التعليمية والحسابات والبيانات والخدمات الرقمية، وحماية البيانات الشخصية واستمرارية تقديم الخدمة للمستخدمين.

النطاق: تنطبق السياسة على الموظفين والمتقاعدين والمتدربين والمستخدمين المصرح لهم باستخدام بوابة الخدمات التعليمية، والبريد الإلكتروني المؤسسي، والحسابات الرقمية، والأجهزة المملوكة للمنشأة أو المتصلة بخدماتها.

السلوكيات الملزمة: يستخدم كل مستخدم حسابيه الشخصي فقط، ويحافظ على سرية بيانات المصادقة، ويغفل الجهاز عند مغادرته، ويتبع فوراً عن الانشغال في وصول غير مصرح به أو فقدان جهاز أو رسالة تصيد، ويقتصر في معالجة البيانات على الغرض الوظيفي أو التعليمي المصرح به.

السلوكيات المحظورة: يحظر مشاركة الحسابات أو كلمات المرور، ومحاولة تجاوز ضوابط التحكم في الوصول، وتحميل برامج غير مصرح بها، وإرسال بيانات شخصية عبر قنوات غير معتمدة، واستخدام حساب مستخدم آخر، وتعطيل الخدمة أو اختيارها دون تفويض مكتوب.

الأدوار والمسؤوليات: المستخدم يلتزم بالبنود ويبلغ عن الحوادث، إدارة تقنية المعلومات تدير الحسابات والأجهزة والدعم الفني- إدارة الأمن السبراني تراقب الالتزام وتقيم المخاطر وتراجع السياسة، المدير المسؤول يعتمد الاستثناءات ذات الأثر العالي بعد تقييم المخاطر.

الاستثناءات الموثقة: لا يسمح أي استثناء إلا بطلب مكتوب يحدد السبب والنطاق والمدة والضوابط البديلة، وبعد تقييم المخاطر وموافقة مالك السياسة والجهة المخولة. تنتهي صلاحية الاستثناء تلقائياً في التاريخ المحدد ما لم يحدد رسمياً.

المخالفة والإجراء التصحيحي: توثق المخالفة في تقرير حادثة أو مخالفة أمنية، ويجري احتواء الأثر وتحليل السبب الجذري وتحديد الإجراء التصحيحي والمسؤول وتاريخ الاستحقاق، مع تطبيق المساءلة وفق النواحي الداخلية والأنظمة ذات العلاقة.

النشر والتوعية: تنشر السياسة في البوابة الداخلية، ويقر المستخدم بالإطلاع عليها عند إنشاء الحساب وعند كل تحديث جوهري، وتنفذ نوعية دورية تشمل رسائل التصيد وحماية الحسابات.

دورية المراجعة: تراجع مرة كل 12 شهراً، أو عند تغير جوهري في الخدمات أو المخاطر أو المتطلبات التنظيمية، بما يتناسب مع الضوابط الوطنية للأمن السبراني ونظام حماية البيانات الشخصية.

هذه الوثيقة نموذج تدريسي، السياسة تحدد ما يجب الالتزام به، أما خطوات تنفيذ إنشاء الحساب أو إيقافه فدر في إجراءات تشغيلية مستقلة.

مقدم الطلب

المسؤول

الاتخاذ

مستند تعليمي إلكتروني، الأسماء والأرقام غير حقيقية

- أقرأ معرف السياسة POL-AUP-2026-017 وإصدارها 1.2 قبل قراءة البنود.
- ثم حدد الغرض والنطاق ومالك السياسة وجهة الاعتماد.
- لاحظ أن الوثيقة تفرق بين السلوكيات الملزمة والمحظورة، وتربط الاستثناء بطلب مكتوب وتقييم مخاطر وموافقة.
- استخدم هذه الحقول لاحقاً لتحليل المخالفة والإجراء التصحيحي.



- ◀ مالك السياسة هو الدور التنظيمي المعين لإدارة تطوير السياسة وتوثيقها ونشرها ومتابعة تحديثها.
- ◀ وجود مالك واضح يمنع بقاء الوثيقة بلا جهة مسؤولة عندما تتغير الخدمات أو تظهر فجوة امتثال.
- ◀ في نموذج الشركة، مالك POL-AUP-2026-017 هو إدارة الأمن السيبراني، بينما الاعتماد من اختصاص الإدارة التنفيذية.
- ◀ **الوظيفة:** ضمان استمرارية دورة حياة السياسة.
- ◀ **المسؤوليات:** إدارة التطوير، توثيق النسخة، نشر الوثيقة، تنسيق المراجعة، متابعة التحديث.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022, NIST CSF 2.0.
- ◀ **الأدوات:** سجل ملكية السياسات، سجل مراجعات، منصة وثائق.
- ◀ **المخرج:** دور مالك محدد في سجل السياسة.
- ◀ **مثال:** إدارة الأمن السيبراني تراجع السياسة عند تغير المخاطر.



مالك السياسة (الشكل)

SLIDE 9 • ELEMENT

مالك السياسة



الأجهزة والأدوات

- سجل ملكية السياسات
- سجل مراجعات
- منصة وثائق

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022
- NIST CSF 2.0

الوظائف الرئيسية

- ضمان استمرارية دورة حياة السياسة
- إدارة التطوير
- توثيق النسخة
- نشر الوثيقة
- تنسيق المراجعة

إدارة الأمن السيبراني تراجع السياسة عند تغير المخاطر.

مالك السياسة هو الدور التنظيمي المعين لإدارة تطوير السياسة وتوثيقها ونشرها ومتابعة تحديثها.



الفئات المستهدفة بالسياسة

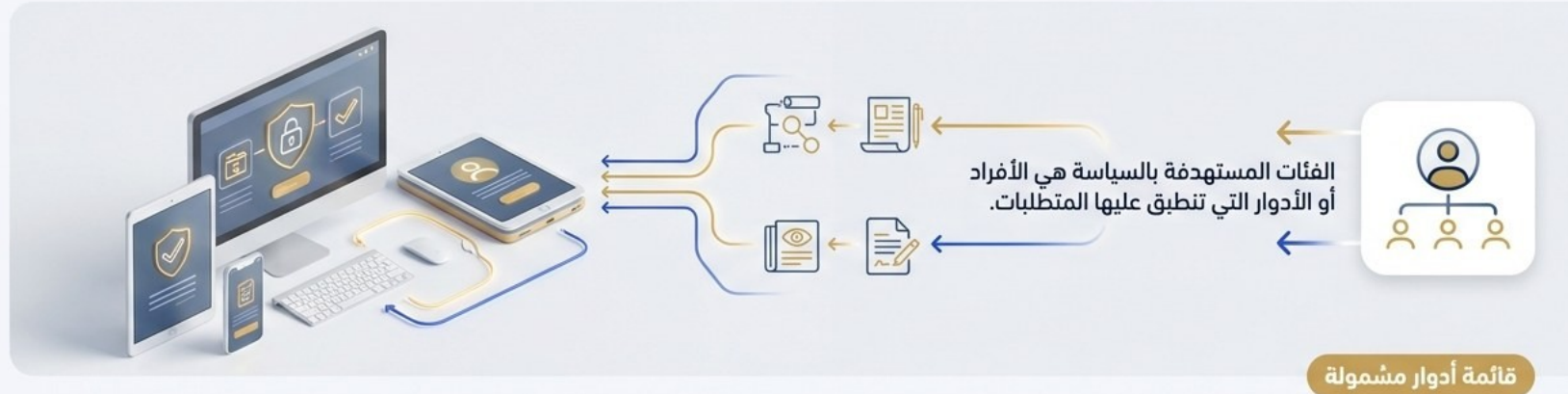
- ◀ الفئات المستهدفة بالسياسة هي الأفراد أو الأدوار التي تنطبق عليها المتطلبات.
- ◀ ترتبط هذه الفئات بالنطاق وبخطة النشر والتوعية والإقرار.
- ◀ لا يعني ذلك أن جميع الفئات تؤدي الواجبات نفسها، بل تتغير مسؤولية المستخدم أو مدير الخدمة أو فريق التقنية بحسب عمله وصلاحياته.
- ◀ تشمل سياسة الشركة الموظفين والمتعاقدين والمتدربين والمستفيدين المصرح لهم.
- ◀ **الوظيفة:** توجيه المتطلبات إلى من يلزمهم التطبيق.
- ◀ **المسؤوليات:** تحديد الفئات، إبلاغ المشمولين، توثيق النشر، متابعة الفهم.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, NIST CSF 2.0, ISO/IEC 27001:2022.
- ◀ **الأدوات:** قائمة توزيع، منصة تعلم، سجل إقرار إلكتروني.
- ◀ **المخرج:** قائمة أدوار مشمولة.
- ◀ **مثال:** المتعاقد يلتزم بالسياسة عند استخدام حساب مؤسسي.



الفئات المستهدفة بالسياسة (الشكل)

SLIDE 10 • ELEMENT

الفئات المستهدفة بالسياسة



الأجهزة والأدوات

- قائمة توزيع
- منصة تعلم
- سجل إقرار إلكتروني

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- NIST CSF 2.0
- ISO/IEC 27001:2022

الوظائف الرئيسية

- توجيه المتطلبات إلى من يلزمهم التطبيق
- تحديد الفئات
- إبلاغ المشمولين
- توثيق النشر
- متابعة الفهم

المتعاقد يلتزم بالسياسة عند استخدام حساب مؤسسي

الفئات المستهدفة بالسياسة هي الأفراد أو الأدوار التي تنطبق عليها المتطلبات. ترتبط هذه الفئات بالنطاق وبخطة النشر والتوعية والإقرار.



- ◀ الأدوار والمسؤوليات توزيع واضح للمهام والصلاحيات والمساءلة المتصلة بالسياسة.
- ◀ وهي تمنع فراغ المسؤولية عند التطبيق أو المراجعة أو معالجة المخالفات.
- ◀ لا يتحمل فريق التقنية وحده التزام جميع الموظفين، لأن لكل طرف واجباً يتناسب مع دوره.
- ◀ **الوظيفة:** تنظيم القرار والتنفيذ والمراجعة.
- ◀ **المسؤوليات:** مالك السياسة، إدارة التطوير والمراجعة، الإدارة المعتمدة، إقرار الوثيقة، المنفذ، تطبيق الضوابط، المراجع، فحص الأدلة، المستخدم الملتزم، اتباع البنود والإبلاغ.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، NIST SP 800-53 Rev. 5، NIST CSF 2.0.
- ◀ **الأدوات:** مصفوفة مسؤوليات، جدول RACI، سجل مهام.
- ◀ **المخرج:** جدول أدوار داخل السياسة.
- ◀ **مثال:** تدير تقنية المعلومات الحسابات، وتراقب إدارة الأمن السيبراني الالتزام.



(الشكل) (Roles and Responsibilities) الأدوار والمسؤوليات

SLIDE 11 · ROLES AND RESPONSIBILITIES

الأدوار والمسؤوليات



الأجهزة والأدوات

- مصفوفة مسؤوليات
- جدول RACI
- سجل مهام

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- NIST SP 800-53 Rev. 5
- NIST CSF 2.0

الوظائف الرئيسية

- تنظيم القرار والتنفيذ والمراجعة
- مالك السياسة
- إدارة التطوير والمراجعة
- الإدارة المعتمدة
- إقرار الوثيقة

تدير تقنية المعلومات الحسابات، وتراقب إدارة الأمن السيبراني الالتزام
الأدوار والمسؤوليات. توزيع واضح للمهام والصلاحيات والمسائلة المتصلة بالسياسة. وهي تمنع فراغ المسؤولية عند التطبيق أو المراجعة أو معالجة المخالفات.



مكونات سياسة أمن المعلومات

المكون	سؤال التحقق	تطبيق على سياسة الشركة
الغرض	ما الذي تنظمه السياسة؟	الاستخدام الآمن للمنصات والحسابات
النطاق	من يشمل التطبيق؟	الموظفون والمتعاقدون والمتدربون والمستفيدون
المالك	من يدير الوثيقة؟	إدارة الأمن السيبراني
الأدوار	من ينفذ ويراجع؟	المستخدم، تقنية المعلومات، الأمن السيبراني
الاستثناءات	كيف يوافق عليها؟	طلب مكتوب وتقييم مخاطر
المراجعة	متى تعدل؟	كل 12 شهراً أو عند تغير جوهري

يبين الجدول أن اكتمال المكونات يجعل المتطلبات قابلة للتطبيق والمراجعة، بدلاً من الاكتفاء بعبارات عامة.



زمن الوحدة: 70 دقيقة.

اقرأ نموذج سياسة الاستخدام المقبول، واستخرج الغرض والنطاق والمالك والأدوار، ثم تحقق من فهمك في اختبار الوحدة.



- ◀ الالتزام بالسياسة هو اتباع المتطلبات ومتابعة تحققها في العمل الفعلي.
- ◀ لا يقتصر الالتزام على نشر الوثيقة أو حصول المستخدم على نسخة منها.
- ◀ يحتاج إلى أدلة مناسبة، مثل سجل الإقرار وسجل المراجعة وسجل الاستثناءات وتقارير المتابعة، حتى تستطيع المؤسسة كشف الفجوات ومعالجتها.
- ◀ **الوظيفة:** تحويل السياسة إلى ممارسة قابلة للمتابعة.
- ◀ **المسؤوليات:** النشر، إيصال المتطلبات، الإقرار، توثيق الاطلاع، المتابعة، جمع الأدلة، معالجة الفجوات، تحسين التطبيق.
- ◀ **البروتوكولات والمعايير:** NIST CSF 2.0, NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022.
- ◀ **الأدوات:** سجل إقرار، تقرير مراجعة، أدلة امتثال، سجل استثناءات.
- ◀ **المخرج:** حالة التزام أو فجوة موثقة.
- ◀ **مثال:** يثبت سجل الدخول تطبيق قيود الوصول، لا مجرد قراءة السياسة.



الالتزام بالسياسة (Compliance) (الشكل)

SLIDE 13 · COMPLIANCE

الالتزام بالسياسة



الأجهزة والأدوات

- سجل إقرار
- تقرير مراجعة
- أدلة امتثال
- سجل استثناءات

البروتوكولات والمعايير

- NIST CSF 2.0
- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022

الوظائف الرئيسية

- تحويل السياسة إلى ممارسة قابلة للمتابعة
- النشر
- إيصال المتطلبات
- الإقرار
- توثيق الاطلاع

يُثبت سجل الدخول تطبيق قيود الوصول، لا مجرد قراءة السياسة.

الالتزام بالسياسة هو اتباع المتطلبات ومتابعة تحققها في العمل الفعلي. لا يقتصر الالتزام على نشر الوثيقة أو حصول المستخدم على نسخة منها.



الاستثناءات الموثقة (Documented Exceptions)

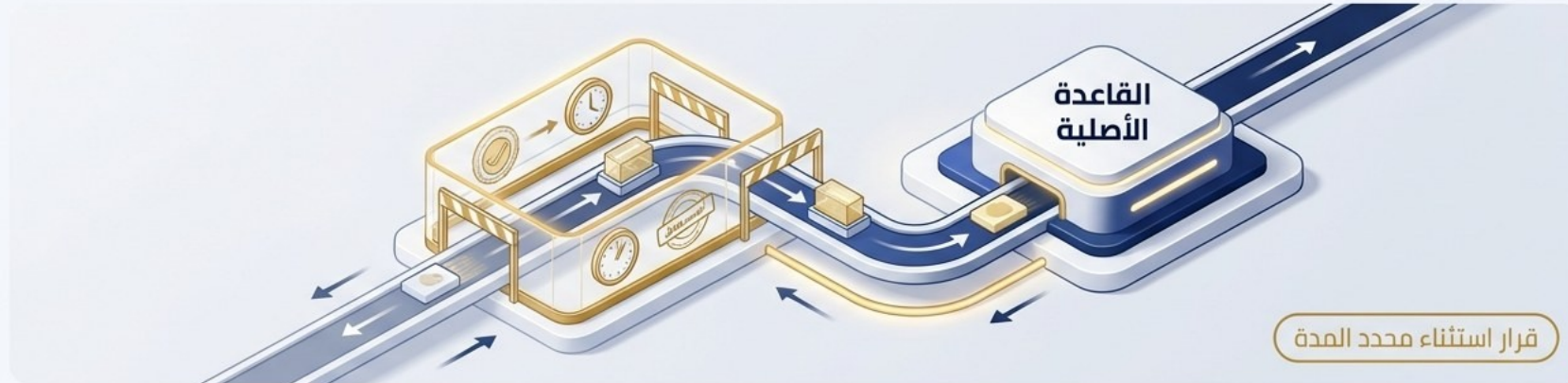
- ◀ الاستثناء الموثق خروج محدود ومعتمد ومؤقت عن متطلب سياسي.
- ◀ لا يلغي الاستثناء القاعدة الأصلية، ولا ينشأ شفهيًا أو بلا تاريخ انتهاء.
- ◀ يوضح طلب EXC-2026-043 سبب الحاجة والنطاق والجهاز المسموح والضوابط البديلة وفترة النفاذ، وتنتهي صلاحيته الإدارية في التاريخ المحدد ما لم يجدد رسمياً.
- ◀ أما الإيقاف التقني للوصول فيتطلب تطبيق الضابط أو الإجراء الداعم.
- ◀ **الوظيفة:** إدارة الحاجة الاستثنائية مع حفظ المخاطر.
- ◀ **المسؤوليات:** طلب الاستثناء، وصف الحاجة، تحليل الأثر، تقدير المخاطر، اعتماد المسؤول، تحديد المدة، مراجعة الإغلاق.
- ◀ **البروتوكولات والمعايير:** NIST CSF 2.0, NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022.
- ◀ **الأدوات:** سجل استثناءات، نموذج موافقة، سجل مخاطر.
- ◀ **المخرج:** قرار استثناء محدد المدة.
- ◀ **مثال:** انتهى EXC-2026-043 في 2026-05-19.



الاستثناءات الموثقة (Documented Exceptions) (الشكل)

SLIDE 14 · DOCUMENTED EXCEPTIONS

الاستثناءات الموثقة



الأجهزة والأدوات

- سجل استثناءات
- نموذج موافقة
- سجل مخاطر

البروتوكولات والمعايير

- NIST CSF 2.0
- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022

الوظائف الرئيسية

- إدارة الحاجة الاستثنائية مع حفظ المخاطر
- طلب الاستثناء
- وصف الحاجة
- تحليل الأثر
- تقدير المخاطر

انتهى EXC-2026-043 في 19-05-2026

الاستثناء الموثق خروج محدود ومعتمد ومؤقت عن مطلب سياسي، لا يلغي الاستثناء القاعدة الأصلية، ولا ينشأ شفهيًا أو بلا تاريخ انتهاء.

طلب استثناء أمني مؤقت

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

النموذج: طلب استثناء من سياسة الاستخدام المقبول

طلب استثناء من سياسة الاستخدام المقبول

رقم الطلب: EXC-2026-043

تاريخ الطلب: 2026-04-22

السياسة ذات العلاقة: AUP-2026-017-POL، سياسة الاستخدام المقبول، الإصدار 1.2

مقدم الطلب: مستخدم مخول من فريق تشغيل المنصة التعليمية

سبب الطلب: الحاجة المؤقتة إلى متابعة طلبات المستخدمين خارج مقر العمل خلال فترة معالجة تحديث طارئ على أجهزة العمل المخصصة.

نطاق الاستثناء المطلوب: السماح باستخدام جهاز شخصي واحد للوصول إلى نظام متابعة طلبات المستخدمين عبر بوابة الويب فقط، دون تنزيل ملفات أو نسخ بيانات أو الوصول إلى لوحة إدارة المنصة.

تاريخ بدء الاستثناء: 2026-04-24

تاريخ انتهاء الاستثناء: 2026-05-19

تقييم المخاطر: الخطر متوسط بسبب احتمال تخزين بيانات على جهاز غير مملوك للمنشأة أو استخدام شبكة غير مؤنقة.

الضوابط البديلة الملزمة: تفعيل المصادقة متعددة العوامل، استخدام اتصال مشفر معتمد، منع تنزيل البيانات والطباعة والنسخ إلى الحافظة، تحديث نظام التشغيل والمتصفح، قفل الجهاز برمز قوي، وعدم استخدام شبكات عامة مفتوحة.

قرار مالك السياسة: موافقة مشروطة بالنطاق والمدة والضوابط البديلة المذكورة، ولا تشمل مشاركة الحساب أو تفويض مستخدم آخر بالدخول.

آلية المتابعة: تراجع سجلات الدخول مرة كل 7 أيام، وإرسال تنبيه آلي قبل انتهاء الاستثناء بيومين، ويوقف الوصول الاستثنائي عند انتهاء الصلاحية.

حالة الطلب: متتو في 2026-05-19، ولا يجوز استخدامه بعد هذا التاريخ دون طلب تجديد مكتوب.

الاعتماد

المسؤول

مقدم الطلب

مستند تليفي إلكتروني الإسماء والأرقام غير حثيثة

◀ اقرأ رقم الطلب EXC-2026-043 واربطه بسياسة الاستخدام المقبول POL-AUP-2026-017. الاستثناء يسمح بجهاز شخصي واحد للوصول عبر بوابة الويب فقط، ويمنع تنزيل الملفات والنسخ والطباعة.

◀ لاحظ أن الموافقة مشروطة بالمصادقة متعددة العوامل والاتصال المشفر، وأن الطلب أصبح منتهياً في 2026-05-19.



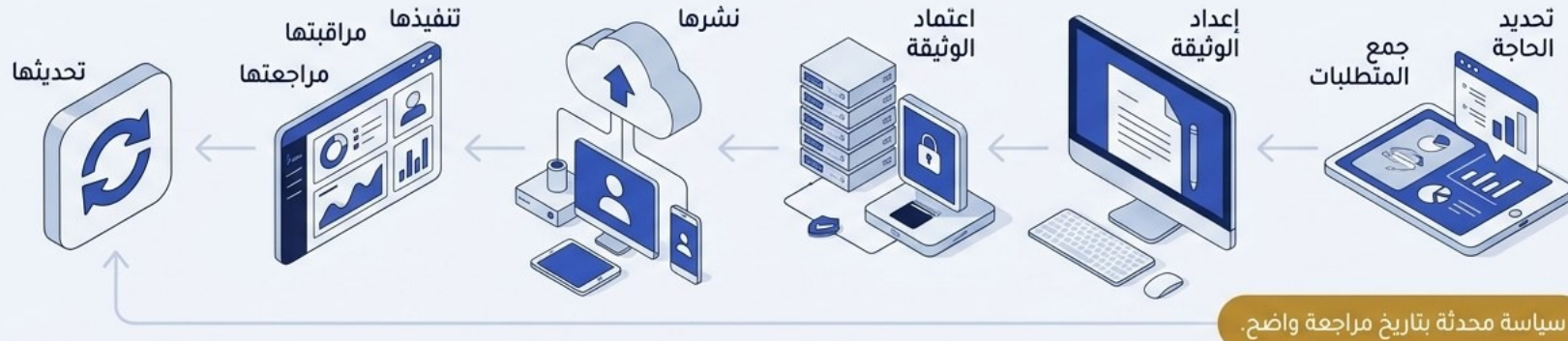
- ◀ دورة حياة السياسة تسلسل إداري يبدأ بتحديد الحاجة وجمع المتطلبات، ثم إعداد الوثيقة واعتمادها ونشرها وتنفيذها ومراقبتها ومراجعتها وتحديثها.
- ◀ هذا ترتيب تعليمي عملي مستند إلى توثيق NIST وتوجيه ISO نحو الإنشاء والتنفيذ والصيانة والتحسين المستمر، ولا يمثل نصاً إلزامياً حرفياً من معيار واحد.
- ◀ **الوظيفة:** إبقاء السياسة مناسبة للمخاطر والعمليات.
- ◀ **المسؤوليات:** تحديد الحاجة، جمع المتطلبات، إعداد المسودة، اعتماد الوثيقة، نشر المتطلبات، مراقبة الالتزام، مراجعة النتائج، تحديث الإصدار.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، NIST SP 800-53 Rev. 5، NIST CSF 2.0.
- ◀ **الأدوات:** سجل مراجعات، سجل إصدار، خطة نشر، قائمة تحقق.
- ◀ **المخرج:** سياسة محدثة بتاريخ مراجعة واضح.
- ◀ **مثال:** أضيف تنبيه انتهاء الاستثناء بعد حادثة مسجلة.



دورة حياة السياسة (الشكل)

SLIDE 16 • ELEMENT

دورة حياة السياسة



الأجهزة والأدوات

- سجل مراجعات
- سجل إصدار
- خطة نشر
- قائمة تحقق

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- NIST SP 800-53 Rev. 5
- NIST CSF 2.0

الوظائف الرئيسية

- إبقاء السياسة مناسبة للمخاطر والعمليات
- تحديد الحاجة
- جمع المتطلبات
- إعداد المسودة
- اعتماد الوثيقة

أضيف تنبيه انتهاء الاستثناء بعد حادثة مسجلة.
دورة حياة السياسة تسلسل إداري يبدأ بتحديد الحاجة وجمع المتطلبات، ثم إعداد الوثيقة واعتمادها ونشرها وتنفيذها ومراقبتها ومراجعتها وتحديثها.



جدول دورة حياة السياسة الأمنية

المرحلة	العمل الرئيس	المخرج
تحديد الحاجة والصياغة	جمع المتطلبات والمخاطر وإعداد المسودة	مسودة سياسة
المراجعة والاعتماد	فحص الغرض والنطاق والأدوار واعتماد الجهة المخولة	إصدار معتمد
النشر والتوعية	إتاحة السياسة وإقرار الفئات المشمولة	سجل نشر وإقرار
التطبيق والمتابعة	تنفيذ المتطلبات وجمع أدلة الالتزام	أدلة وفجوات
المراجعة والتحديث	فحص النتائج والحوادث وتحديث الإصدار عند الحاجة	قرار إبقاء أو تعديل

ينظم الجدول مراحل دورة الحياة في تسلسل قابل للمتابعة.
يربط المتعلم كل مرحلة بعمل محدد ومخرج يوثق انتقال السياسة إلى المرحلة التالية، ويستطيع مقارنة هذا التسلسل بسجل المراجعة في الشريحة التالية.

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستفيدين
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: سجل مراجعة واعتماد سياسة الاستخدام المقبول

سجل مراجعة واعتماد سياسة الاستخدام المقبول

AUP-2026-017-POL | سجل دورة الحياة والسيطرة على الوثيقة

التاريخ	المرحلة	الجهة المسؤولة	القرار أو الملاحظة	الأثر على الوثيقة
2026-01-19	تقييم المخاطر وجمع المتطلبات	إدارة الأمن السبراني	رصد مخاطر مشاركة الحسابات واستخدام أجهزة غير محدثة ووصول متعاقدين إلى بيانات لا تلتزمهم.	إضافة بنود صريحة للحسابات الشخصية والتحكم في الوصول والإبلاغ عن الحوادث.
2026-02-03	مراجعة قابلية التطبيق	إدارة تقنية المعلومات وإدارة الأمن السبراني	تبين أن تغيير كلمة المرور كل 7 أيام أدى إلى طلبات دعم متكررة وسلوكيات غير آمنة، ويوصى بالمصادقة متعددة العوامل وكلمات مرور طويلة بدلاً من تغيير دوري قصير غير مبرر.	تعديل الإجراء التشغيلي للمصادقة وربطه بمتطلب الإبلاغ عند الاشتباه بالاختراق.
2026-02-17	اعتماد	الإدارة التنفيذية	اعتماد الإصدار 1.2 بعد التحقق من الغرض والنطاق والأدوار وآلية الاستثناءات.	اعتماد السياسة بتاريخ 2026-02-17.
2026-03-01	نشر وتوعية	إدارة تقنية المعلومات وإدارة الأمن السبراني	نشر السياسة في البوابة الداخلية وتفعيل إقرار الاطلاع للمستخدمين عند الدخول.	بدء النفاذ وإتاحة سجل الإقرارات.
2026-05-26	مراجعة حادثة ومتابعة	إدارة الأمن السبراني	وردت مخالفة لمشاركة بيانات دخول مرتبطة بطلب استثناء منتهي الصلاحية، ويستلزم ذلك توعية مستهدفة وتحسين متابعة انتهاء الاستثناءات.	تسجيل إجراء تصحيحي وربط تنبيه انتهاء الصلاحية بسجل الاستثناءات.
2026-11-18	مراجعة دورية	مالك السياسة	مراجعة نتائج الالتزام والحوادث وطلبات الاستثناء خلال الفترة، دون تغيير في الغرض أو النطاق.	تأكيد استمرار الإصدار 1.2 وتحديد المراجعة التالية في 2027-11-18.

السجل يوضح أن اعتماد السياسة لا يكفي وحده، بل يلزم النشر والقياس والتحديث عند ظهور أدلة تشغيلية أو حوادث.

مستند تعليمي افتراضي. الأسماء والأرقام غير حقيقية

اتبع تسلسل السجل من 2026-01-19 حتى 2026-11-18. بدأت الشركة بجمع المتطلبات وتقييم المخاطر، ثم راجعت قابلية التطبيق في 2026-02-03، واعتمدت الإصدار 1.2 في 2026-02-17، ونشرته في 2026-03-01. سجلت لاحقاً حادثة مرتبطة باستثناء منه، ثم أكدت استمرار الإصدار بعد المراجعة الدورية.



- ◀ اعتماد السياسة هو إقرار الجهة المخولة بأن الوثيقة صالحة للنشر والتطبيق.
- ◀ يثبت الاعتماد التزام الإدارة ويمنح السياسة سلطة تنظيمية داخل المؤسسة.
- ◀ لا تعد المسودة سياسة نهائية لمجرد تداولها بين الموظفين.
- ◀ في الشركة، اعتمدت الإدارة التنفيذية الإصدار 1.2 من سياسة الاستخدام المقبول بتاريخ 2026-02-17.
- ◀ **الوظيفة:** توثيق قبول الإدارة للسياسة.
- ◀ **المسؤوليات:** إعداد المسودة، مراجعة المعنيين، اعتماد الإدارة، توثيق القرار.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022, NIST CSF 2.0.
- ◀ **الأدوات:** سجل اعتماد، توقيع إلكتروني، منصة إدارة وثائق.
- ◀ **المخرج:** وثيقة معتمدة بإصدار وتاريخ ومالك.
- ◀ **مثال:** الاعتماد سبق تاريخ النفاذ في 2026-03-01.



SLIDE 18 · ELEMENT

اعتماد السياسة



الأجهزة والأدوات

- سجل اعتماد
- توقيع إلكتروني
- منصة إدارة وثائق

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022
- NIST CSF 2.0

الوظائف الرئيسية

- توثيق قبول الإدارة للسياسة
- إعداد المسودة
- مراجعة المعنيين
- اعتماد الإدارة
- توثيق القرار

الاعتماد سبق تاريخ النفاذ في 2026-03-01.

اعتماد السياسة هو إقرار الجهة المخولة بأن الوثيقة صالحة للنشر والتطبيق. يثبت الاعتماد التزام الإدارة ويمنح السياسة سلطة تنظيمية داخل المؤسسة.



- ◀ نشر السياسة إيصال الوثيقة المعتمدة إلى الفئات المشمولة بها بصورة منظمة يمكن إثباتها.
- ◀ يختلف النشر عن وضع ملف في مجلد غير معلن، لأن الفئة المستهدفة يجب أن تعرف مكان الوثيقة وما المطلوب منها.
- ◀ نشرت الشركة سياستها في البوابة الداخلية وفعلت إقرار الاطلاع عند إنشاء الحساب وعند كل تحديث جوهري.
- ◀ **الوظيفة:** تمكين التطبيق وإثبات الإتاحة.
- ◀ **المسؤوليات:** تحديد الجمهور، نشر الوثيقة، إتاحة النسخة، تنفيذ التوعية، حفظ السجل.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, NIST CSF 2.0, ISO/IEC 27001:2022.
- ◀ **الأدوات:** بوابة داخلية، بريد مؤسسي، منصة تعلم، سجل إقرار.
- ◀ **المخرج:** سجل نشر أو إقرار بالاطلاع.
- ◀ **مثال:** بدأ نفاذ السياسة في 2026-03-01.



SLIDE 19 · ELEMENT

نشر السياسة



الأجهزة والأدوات

- بوابة داخلية
- بريد مؤسسي
- منصة تعلم
- سجل إقرار

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- NIST CSF 2.0
- ISO/IEC 27001:2022

الوظائف الرئيسية

- تمكين التطبيق وإثبات الإتاحة
- تحديد الجمهور
- نشر الوثيقة
- إتاحة النسخة
- تنفيذ التوعية

بدأ نفاذ السياسة في 2026-03-01.

نشر السياسة إيصال الوثيقة المعتمدة إلى الفئات المشمولة بها بصورة منظمة يمكن إثباتها.



- ◀ مراجعة السياسة فحص منتظم أو مرتبط بحدث للتأكد من أن الوثيقة ما زالت مناسبة وفعالة.
- ◀ قد تدفع الحوادث أو تغير الخدمات أو تغير المخاطر إلى تعديل السياسة أو إجراءاتها.
- ◀ في سجل الشركة، راجع مالك السياسة نتائج الالتزام والحوادث وطلبات الاستثناء في 2026-11-18، وأبقى الإصدار 1.2 دون تغيير في الغرض أو النطاق.
- ◀ **الوظيفة:** معالجة التغير والتحسين المستمر.
- ◀ **المسؤوليات:** تحديد الدورية، مراجعة الوقائع، اعتماد التعديل، نشر الإصدار الجديد.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, NIST CSF 2.0, ISO/IEC 27001:2022.
- ◀ **الأدوات:** سجل مراجعة، سجل تغييرات، تقارير حوادث.
- ◀ **المخرج:** قرار إبقاء أو تعديل أو إلغاء.
- ◀ **مثال:** حددت المراجعة التالية في 2027-11-18.
- ◀ زمن الوحدة: 70 دقيقة.
- ◀ قارن بين السياسة العليا والسياسات الموضوعية والإجراء والمعيار الداخلي، ثم صنف متطلبات بوابة الخدمات بحسب الوثيقة المناسبة.



SLIDE 20 • ELEMENT

مراجعة السياسة



الأجهزة والأدوات

- سجل مراجعة
- سجل تغييرات
- تقارير حوادث

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- NIST CSF 2.0
- ISO/IEC 27001:2022

الوظائف الرئيسية

- معالجة التغير والتحسين المستمر
- تحديد الدورية
- مراجعة الوقائع
- اعتماد التعديل
- نشر الإصدار الجديد

حددت المراجعة التالية في 2027-11-18.

مراجعة السياسة فحص منظم أو مرتبط بحدث للتأكد من أن الوثيقة ما زالت مناسبة وفعالة.



- ◀ سياسة أمن المعلومات العليا وثيقة توجيهية على مستوى المؤسسة تربط حماية المعلومات بالحوكمة وإدارة المخاطر والأهداف التنظيمية.
- ◀ لا تشرح هذه السياسة خطوات تشغيلية تفصيلية، بل توفر الإطار الذي تبني عليه السياسات الموضوعية والإجراءات والمعايير الداخلية.
- ◀ تساعد الإدارة على متابعة الاتجاه العام لحماية البيانات والخدمات.
- ◀ **الوظيفة:** توحيد التوجه الأمني المؤسسي.
- ◀ **المسؤوليات:** تحديد الاتجاه، ربط الأمن بالأعمال، اعتماد السياسات الفرعية، متابعة التحسين.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، NIST CSF 2.0، NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** وثيقة سياسة عليا، سجل سياسات فرعية، لوحة متابعة حوكمة.
- ◀ **المخرج:** بيان سياسة أمن معلومات للمؤسسة.
- ◀ **مثال:** تربط السياسة العليا حماية بيانات المستفيدين بالمسؤوليات المؤسسية.



SLIDE 21 · ELEMENT

سياسة أمن المعلومات العليا



الأجهزة والأدوات

- وثيقة سياسة عليا
- سجل سياسات فرعية
- لوحة متابعة حوكمة

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- NIST CSF 2.0
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- توحيد التوجه الأمني المؤسسي
- تحديد الاتجاه
- ربط الأمن بالأعمال
- اعتماد السياسات الفرعية
- متابعة التحسين

تربط السياسة العليا حماية بيانات المستخدمين بالمسؤوليات المؤسسية.

سياسة أمن المعلومات العليا وثيقة توجيهية على مستوى المؤسسة تربط حماية المعلومات بالحوكمة وإدارة المخاطر والأهداف التنظيمية.



مقارنة أنواع السياسات الأمنية

نوع السياسة	الغرض	الفئة المستهدفة	مثال في الشركة
سياسة أمن المعلومات العليا	توجيه الحوكمة العامة	الإدارة والأدوار المؤسسية	ربط الأمن بإدارة المخاطر
سياسة الاستخدام المقبول	تنظيم الاستخدام المشروع	المستخدمون والمتعاقدون	POL-AUP-2026-017
سياسة التحكم في الوصول	تنظيم منح الصلاحيات	مالكو الخدمات وتقنية المعلومات	مراجعة صلاحيات الحسابات
سياسة العمل عن بعد	تنظيم الوصول خارج المقر	الموظفون المخولون	استخدام قناة المؤسسة المعتمدة
سياسة تصنيف البيانات	تنظيم التعامل مع المعلومات	مالكو البيانات والمستخدمون	وسم الملف الداخلي



مقارنة أنواع السياسات الأمنية (تابع)



- ◀ تختلف السياسة بحسب نطاقها والجمهور الذي يخضع لمتطلباتها.
- ◀ ويمكن تنظيمها تعليمياً في شجرة تبدأ بالسياسة العليا ثم تتفرع إلى سياسات موضوعية، مثل الاستخدام المقبول والتحكم في الوصول، وتدعمها إجراءات ومعايير داخلية مرتبطة بكل خدمة.



- ◀ سياسة الاستخدام المقبول تنظم الاستخدامات المقبولة وغير المقبولة للموارد والخدمات المعلوماتية.
- ◀ تحدد السلوك المتوقع من المستخدم، وتحظر مشاركة الحسابات أو تجاوز ضوابط التحكم في الوصول أو استخدام الحسابات لأغراض غير مصرح بها.
- ◀ لا تكفي قائمة منع فقط، بل يجب أن تبين النطاق والمسؤوليات ومسار الإبلاغ.
- ◀ **الوظيفة:** توضيح السلوك المتوقع وحماية الموارد.
- ◀ **المسؤوليات:** تعريف المستخدم، تحديد الموارد، بيان الممنوعات، الإبلاغ عن المخالفات، قبول الالتزام.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022, ISO/IEC 27002:2022, NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** نموذج إقرار، بوابة خدمات، بريد مؤسسي، أجهزة عمل.
- ◀ **المخرج:** وثيقة سياسة وإقرار مستخدم.
- ◀ **مثال:** تحظر POL-AUP-2026-017 مشاركة كلمات المرور والحسابات.



سياسة الاستخدام المقبول (Acceptable Use Policy) (الشكل)



SLIDE 23 · ACCEPTABLE USE POLICY

سياسة الاستخدام المقبول



الأجهزة والأدوات

- نموذج إقرار
- بوابة خدمات
- بريد مؤسسي
- أجهزة عمل

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- توضيح السلوك المتوقع وحماية الموارد
- تعريف المستخدم
- تحديد الموارد
- بيان الممنوعات
- الإبلاغ عن المخالفات

تحتفظ POL-AUP-2026-017 بمشاركة كلمات المرور والحسابات

سياسة الاستخدام المقبول تنظم الاستخدامات المقبولة وغير المقبولة للموارد والخدمات المعلوماتية



- ◀ سياسة كلمة المرور سياسة موضوعية تنظم استخدام كلمات المرور ووسائل المصادقة المرتبطة بالحسابات.
- ◀ تدعم حماية الوصول إلى الأنظمة والمعلومات، لكن فاعليتها ترتبط بقابلية التطبيق وسلوك المستخدم.
- ◀ في الشركة، أدى التغيير كل 7 أيام مع متطلبات معقدة إلى ممارسات غير آمنة، فاستدعى ذلك تحسين الإجراء الداعم للمصادقة.
- ◀ **الوظيفة:** حماية الحسابات من الاستخدام غير المصرح به.
- ◀ **المسؤوليات:** المستخدم يحمي بيانات الاعتماد، الإدارة تحدد المتطلبات، تقنية المعلومات تطبق الضوابط.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27002:2022، ISO/IEC 27001:2022، NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** نظام هوية، مدير كلمات مرور مؤسسي، مصادقة متعددة العوامل.
- ◀ **المخرج:** متطلبات مصادقة موثقة.
- ◀ **مثال:** يمنع المستخدم مشاركة كلمة المرور مع زميل.



SLIDE 24 • ELEMENT

سياسة كلمة المرور



الأجهزة والأدوات

- نظام هوية
- مدير كلمات مرور مؤسسي
- مصادقة متعددة العوامل

البروتوكولات والمعايير

- ISO/IEC 27002:2022
- ISO/IEC 27001:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- حماية الحسابات من الاستخدام غير المصرح به
- المستخدم يحمي بيانات الاعتماد
- الإدارة تحدد المتطلبات
- تقنية المعلومات تطبق الضوابط

يمنع المستخدم مشاركة كلمة المرور مع زميل

سياسة كلمة المرور سياسة موضوعية تنظم استخدام كلمات المرور ووسائل المصادقة المرتبطة بالحسابات.



- ◀ سياسة التحكم في الوصول تنظم منح الوصول إلى المعلومات والأنظمة ومراجعته وإلغائه وفق الأدوار والحاجة.
- ◀ تقلل السياسة خطر الوصول غير المصرح به عندما تحدد صاحب الموافقة والمنفذ والمراجع والمستخدم.
- ◀ لا يبرر الاستثناء مشاركة الحساب، حتى لو كان الوصول مؤقتاً أو مرتبطاً بضغط العمل.
- ◀ **الوظيفة:** الحد من الوصول غير المصرح به.
- ◀ **المسؤوليات:** مالك الخدمة يوافق، فريق التقنية ينفذ، المدير يراجع الحاجة، المستخدم يلتزم بالصلاحيات.
- ◀ **البروتوكولات والمعايير:** 5. NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022, ISO/IEC 27002:2022.
- ◀ **الأدوات:** نظام إدارة الهوية، سجل صلاحيات، مراجعة حسابات، نظام طلب وصول.
- ◀ **المخرج:** قرار وصول وسجل صلاحية.
- ◀ **مثال:** يقتصر وصول الموظف على البيانات اللازمة لمهمته.



سياسة التحكم في الوصول (Access Control Policy) (الشكل)

SLIDE 25 · ACCESS CONTROL POLICY

سياسة التحكم في الوصول



الأجهزة والأدوات

- نظام إدارة الهوية
- سجل صلاحيات
- مراجعة حسابات
- نظام طلب وصول

البروتوكولات والمعايير

- ISO/IEC 27002:2022
- ISO/IEC 27001:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- الحد من الوصول غير المصرح به
- مالك الخدمة يوافق
- فريق التقنية ينفذ
- المدير يراجع الحاجة
- المستخدم يلتزم بالصلاحيات

يقتصر وصول الموظف على البيانات اللازمة لمهمته.

سياسة التحكم في الوصول تنظم منح الوصول إلى المعلومات والأنظمة ومراجعتها وإلغائها وفق الأدوار والحاجة.



- ◀ سياسة البريد الإلكتروني سياسة موضوعية تحكم الاستخدام المؤسسي للبريد وتحمي المعلومات المتداولة عبره.
- ◀ تركز على التحقق من المستلمين والمرفقات والقنوات المعتمدة، خصوصاً عند التعامل مع بيانات شخصية.
- ◀ لا يكفي الاعتماد على عنوان البريد فقط، لأن الخطأ في اختيار المستلم أو استخدام قناة غير معتمدة قد يخالف السياسة.
- ◀ **الوظيفة:** تقليل الإرسال غير الملائم للمعلومات.
- ◀ **المسؤوليات:** المستخدم يتحقق من المستلمين، المؤسسة تحدد القواعد، تقنية المعلومات توفر القنوات المعتمدة.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, ISO/IEC 27002:2022, ISO/IEC 27001:2022.
- ◀ **الأدوات:** خدمة بريد مؤسسية، قائمة توزيع، تصنيف رسالة، قنوات مشاركة معتمدة.
- ◀ **المخرج:** رسالة مؤسسية أو سجل استخدام.
- ◀ **مثال:** يمنع إرسال بيانات شخصية إلى بريد شخصي غير معتمد.



سياسة البريد الإلكتروني (الشكل)

SLIDE 26 • ELEMENT

سياسة البريد الإلكتروني



الأجهزة والأدوات

- خدمة بريد مؤسسية
- قائمة توزيع
- تصنيف رسالة
- قنوات مشاركة معتمدة

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- ISO/IEC 27002:2022
- ISO/IEC 27001:2022

الوظائف الرئيسية

- تقليل الإرسال غير اللائق للمعلومات
- المستخدم يتحقق من المستلمين
- المؤسسة تحدد القواعد
- تقنية المعلومات توفر القنوات المعتمدة

يمنع إرسال بيانات شخصية إلى بريد شخصي غير معتمد

سياسة البريد الإلكتروني سياسة موضوعية تحكم الاستخدام المؤسسي للبريد وتحمي المعلومات المتداولة عبره



- ◀ سياسة الأجهزة المحمولة تنظم استخدام الهواتف الذكية والحواسيب المحمولة عند الوصول إلى معلومات المؤسسة أو خدماتها.
- ◀ تربط السياسة بين قابلية نقل الجهاز وحماية البيانات، وتحدد مسؤولية المستخدم والمؤسسة وفريق التقنية.
- ◀ لا يفترض أن الجهاز الشخصي يطبق تلقائياً مستوى الحماية نفسه الذي توفره الأجهزة المؤسسية.
- ◀ **الوظيفة:** مواءمة الحماية مع مخاطر التنقل.
- ◀ **المسؤوليات:** المستخدم يحمي الجهاز، المؤسسة تحدد الاستخدام، تقنية المعلومات تدير الضوابط.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ISO/IEC 27002:2022، NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** هاتف ذكي، حاسب محمول، إدارة أجهزة محمولة.
- ◀ **المخرج:** إقرار استخدام جهاز أو سجل جهاز مؤسسي.
- ◀ **مثال:** منع تخزين ملفات المؤسسة في تطبيق شخصي غير معتمد.



سياسة الأجهزة المحمولة (الشكل)

SLIDE 27 • ELEMENT

سياسة الأجهزة المحمولة



الأجهزة والأدوات

- هاتف ذكي
- حاسب محمول
- إدارة أجهزة محمولة

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- موازنة الحماية مع مخاطر التنقل
- المستخدم يحمي الجهاز
- المؤسسة تحدد الاستخدام
- تقنية المعلومات تدير الضوابط

منع تخزين ملفات المؤسسة في تطبيق شخصي غير معتمد.

سياسة الأجهزة المحمولة تنظم استخدام الهواتف الذكية والحواسيب المحمولة عند الوصول إلى معلومات المؤسسة أو خدماتها.



- ◀ سياسة العمل عن بعد تحدد قواعد الوصول والعمل الآمن خارج مواقع المؤسسة.
- ◀ تبين مسؤولية العامل عن حماية بيئة العمل والملفات والحسابات، وتحدد دور المدير وفريق التقنية ومالك السياسة.
- ◀ تتطلب السياسة قناة وصول معتمدة وفق مخاطر المؤسسة، ولا تفرض المصادر المستخدمة بروتوكول اتصال واحداً لجميع البيئات.
- ◀ **الوظيفة:** تنظيم الوصول الخارجي إلى الموارد.
- ◀ **المسؤوليات:** الموظف يحمي البيئة، المدير يحدد الحاجة، تقنية المعلومات توفر الوصول، مالك السياسة يراجع المتطلبات.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022, ISO/IEC 27002:2022, NIST CSF 2.0.
- ◀ **الأدوات:** حاسب عمل، خدمة وصول مؤسسية، منصة تعاون معتمدة.
- ◀ **المخرج:** إقرار عمل عن بعد أو قواعد وصول موثقة.
- ◀ **مثال:** يستخدم الموظف القناة المعتمدة للوصول إلى الملفات الداخلية.



سياسة العمل عن بعد (الشكل)

SLIDE 28 · ELEMENT

سياسة العمل عن بعد



إقرار عمل عن بعد أو قواعد وصول موثقة

الأجهزة والأدوات

- حاسب عمل
- خدمة وصول مؤسسية
- منصة تعاون معتمدة

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST CSF 2.0

الوظائف الرئيسية

- تنظيم الوصول الخارجي إلى الموارد
- الموظف يحمي البيئة
- المدير يحدد الحاجة
- تقنية المعلومات توفر الوصول
- مالك السياسة يراجع المتطلبات

يستخدم الموظف القناة المعتمدة للوصول إلى الملفات الداخلية

سياسة العمل عن بعد تحدد قواعد الوصول والعمل الآمن خارج مواقع المؤسسة



- ◀ سياسة تصنيف البيانات تنظم تصنيف المعلومات وتحدد طريقة التعامل معها بحسب حساسيتها واحتياجات حمايتها.
- ◀ تساعد السياسة على مواءمة مستوى الحماية مع طبيعة البيانات، فلا تعامل كل المعلومات بالطريقة نفسها.
- ◀ تعتمد الفاعلية على تحديد مالك البيانات ودور المستخدم ودعم تقنية المعلومات للضوابط الملائمة للتصنيف.
- ◀ **الوظيفة:** مواءمة الحماية مع حساسية المعلومات.
- ◀ **المسؤوليات:** مالك البيانات يحدد التصنيف، المستخدم يلتزم بالوسم، تقنية المعلومات تدعم الضوابط.
- ◀ **البروتوكولات والمعايير:** 5 Rev. NIST SP 800-53, ISO/IEC 27002:2022, ISO/IEC 27001:2022.
- ◀ **الأدوات:** سجل بيانات، وسم تصنيف، مستودع وثائق، قواعد مشاركة.
- ◀ **المخرج:** تصنيف بيانات أو وسم تعامل.
- ◀ **مثال:** يوسم ملف تشغيلي بأنه داخلي قبل مشاركته.
- ◀ زمن الوحدة: 70 دقيقة.
- ◀ تتبع سجل المراجعة والاعتماد، واربط كل مرحلة بالجهة المسؤولة والمخرج المتوقع، ثم ابن تسلسلاً لدورة حياة السياسة.



سياسة تصنيف البيانات (الشكل)

SLIDE 29 · ELEMENT

سياسة تصنيف البيانات



تصنيف بيانات أو وسم تعامل

الأجهزة والأدوات

- سجل بيانات
- وسم تصنيف
- مستودع وثائق
- قواعد مشاركة

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- مواءمة الحماية مع حساسية المعلومات
- مالك البيانات يحدد التصنيف
- المستخدم يلتزم بالوسم
- تقنية المعلومات تدعم الضوابط

يوسم ملف تشغيلي بأنه داخلي قبل مشاركته

سياسة تصنيف البيانات تنظم تصنيف المعلومات وتحدد طريقة التعامل معها بحسب حساسيتها واحتياجات حمايتها.



- ◀ السياسة تحدد ما يلزم تحقيقه، بينما يشرح الإجراء كيف ينفذ العامل أو الدور ذلك المتطلب عملياً.
- ◀ يفصل هذا التمييز التوجيه الإداري عن الخطوات التشغيلية التي قد تتغير عند تغير التقنية أو سير العمل.
- ◀ لا تشكل إعادة صياغة الضوابط وحدها سياسة أو إجراءً تنظيمياً كاملاً.
- ◀ **الوظيفة:** ربط الالتزام بالتنفيذ العملي.
- ◀ **المسؤوليات:** مالك السياسة يحدد الالتزام، مالك الإجراء يشرح التنفيذ، المراجع يتحقق من التوافق.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022, ISO/IEC 27002:2022.
- ◀ **الأدوات:** وثيقة سياسة، دليل إجراء، قائمة تحقق، سجل تنفيذ.
- ◀ **المخرج:** سياسة مع إجراءات مرتبطة.
- ◀ **مثال:** تلزم السياسة بمراجعة الصلاحيات، ويحدد الإجراء من يراجعها وكيف يوثق النتيجة.



العلاقة بين السياسة والإجراء (الشكل)

SLIDE 30 • ELEMENT

العلاقة بين السياسة والإجراء



الأجهزة والأدوات

- وثيقة سياسة
- دليل إجراء
- قائمة تحقق
- سجل تنفيذ

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022
- ISO/IEC 27002:2022

الوظائف الرئيسية

- ربط الالتزام بالتنفيذ العملي
- مالك السياسة يحدد الالتزام
- مالك الإجراء يشرح التنفيذ
- المراجع يتحقق من التوافق

تلتزم السياسة بمراجعة الصلاحيات، ويحدد الإجراء من يراجعها وكيف يوثق النتيجة.

السياسة تحدد ما يلزم تحقيقه، بينما يشرح الإجراء كيف ينفذ العامل أو الدور ذلك المتطلب عملياً.



العلاقة بين السياسة والمعيار الداخلي



- ◀ السياسة توضح التزام المؤسسة، بينما يحدد المعيار الداخلي مستوى أو مواصفة تنفيذية أكثر تفصيلاً.
- ◀ يحافظ هذا الفصل على وضوح الطبقات التنظيمية بين القرار الإداري والتفصيل الفني أو التشغيلي.
- ◀ لا ينبغي نقل إعداد تقني متغير إلى سياسة عليا، لأن ذلك يجعل تحديثها صعباً ويخلط بين الوثائق.
- ◀ **الوظيفة:** تنظيم الطبقات الوثائقية للمؤسسة.
- ◀ **المسؤوليات:** الإدارة تعتمد السياسة، الجهة المختصة تعتمد المعيار، المراجع يتحقق من الاتساق.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022, ISO/IEC 27002:2022, NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** مكتبة سياسات، معايير داخلية، إجراءات، سجل استثناءات.
- ◀ **المخرج:** سياسة عليا ومعيار داخلي تابع.
- ◀ **مثال:** تلزم السياسة بحماية الوصول، ويحدد المعيار الإعدادات المعتمدة.



العلاقة بين السياسة والمعيار الداخلي (الشكل)

SLIDE 31 • ELEMENT

العلاقة بين السياسة والمعيار الداخلي



سياسة عليا ومعيار داخلي تابع.

الأجهزة والأدوات

- مكتبة سياسات
- معايير داخلية
- إجراءات
- سجل استثناءات

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- تنظيم الطبقات الوثائقية للمؤسسة
- الإدارة تعتمد السياسة
- الجهة المختصة تعتمد المعيار
- المراجع يتحقق من الاتساق

تلتزم السياسة بحماية الوصول، ويحدد المعيار الإعدادات المعتمدة.
السياسة توضح التزام المؤسسة، بينما يحدد المعيار الداخلي مستوى أو مواصفة تنفيذية أكثر تفصيلاً.



- ◀ قابلية تطبيق السياسة هي مدى إمكان تنفيذها وفهمها ومواءمتها لحجم المؤسسة واحتياجاتها ومخاطرها.
- ◀ السياسة غير القابلة للتطبيق قد تدفع المستخدم إلى سلوكيات التفافية تضعف الحماية.
- ◀ لذلك تستفيد المؤسسة من مدخلات الأدوار المتأثرة، ومن اختبار الوضوح، ومن متابعة الأدلة بعد النشر.
- ◀ **الوظيفة:** تقليل الفجوة بين النص والممارسة.
- ◀ **المسؤوليات:** تحديد احتياج العمل، إشراك الأدوار، اختبار الوضوح، متابعة الالتزام.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022, NIST CSF 2.0, NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** مراجعة سياسة، ورشة أصحاب مصلحة، سجل ملاحظات، نموذج استثناء.
- ◀ **المخرج:** سياسة قابلة للتنفيذ.
- ◀ **مثال:** عولج أثر التغيير المتكرر لكلمات المرور في سجل المراجعة.



قابلية تطبيق السياسة (الشكل)

SLIDE 32 • ELEMENT

قابلية تطبيق السياسة



الأجهزة والأدوات

- مراجعة سياسة
- ورشة أصحاب مصلحة
- سجل ملاحظات
- نموذج استثناء

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- NIST CSF 2.0
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- تقليل الفجوة بين النص والممارسة
- تحديد احتياج العمل
- إشراك الأدوار
- اختبار الوضوح
- متابعة الالتزام

عولج أثر التغيير المتكرر لكلمات المرور في سجل المراجعة

قابلية تطبيق السياسة هي مدى إمكان تنفيذها وفهمها ومواءمتها لحجم المؤسسة واحتياجاتها ومخاطرها.

تحليل قابلية تطبيق سياسة كلمة المرور

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 خانة لجميع الحسابات.	إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل، وإلزام تغيير بيانات الاعتماد عند الاشتباه بالاختراق أو عند صدور تنبيه أمني موثق.	الضابط القابل للتطبيق يقلل السلوكيات الالتفافية مثل تدوين كلمات المرور، ويركز على طول مناسب ومصادقة متعددة العوامل والاستجابة لمؤشرات الخطر.
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.	تسجيل الممارسة كمخاطرة، إزالة البيانات المكتوبة بصورة آمنة، تفعيل دعم لعبارات المرور ومدير كلمات مرور معتمد عند توفره، وتنفيذ توعية تشرح عدم مشاركة أو تدوين بيانات الدخول في أماكن مكشوفة.	السلوك الفعلي دليل على أن صياغة السياسة أو الإجراء لا تحقق الهدف الأمني، ويستلزم معالجة السبب التشغيلي وليس الاكتفاء بالعقوبة.
3	انتهى الاستثناء EXC-2026-043، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.	إيقاف الوصول الاستثنائي فوراً، إعادة تعيين بيانات الاعتماد، مراجعة السجلات، توثيق المخالفة في INC-2026-058، وتفعيل إيقاف تلقائي وتنبيه قبل انتهاء الاستثناء.	الاستثناء يجب أن يكون مؤقتاً ومحددًا بالنطاق والمدة، ولا يحيز مشاركة الحسابات أو الاستمرار بعد انتهاء الموافقة.
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقروا الاطلاع على السياسة فقط.	إضافة مؤشرات تشمل نسبة تفعيل المصادقة متعددة العوامل، وعدد الاستثناءات المنتهية غير المغلقة، وزمن معالجة بلاغات الحسابات، ونتائج مراجعة سجلات الدخول.	إقرار الاطلاع مؤشر نشر وتوعية، لكنه لا يكفي لقياس الامتثال الفعلي أو فاعلية الضوابط.

يكشف المحرك الإيجابية النموذجية تدريجياً بعد أن يصنف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

تعرض ورقة العمل أربع حالات مرتبطة بالمصادقة والالتزام.

في الصف الأول، قارن بين التغيير كل 7 أيام ومنع آخر 24 كلمة مرور، وبين الإجراء المصحح الذي يركز على عبارة مرور مناسبة والمصادقة متعددة العوامل.

في الصف الثالث، اربط انتهاء EXC-2026-043 بتوثيق المخالفة في INC-2026-058.



- ◀ قياس الالتزام بالسياسة جمع أدلة مناسبة لمعرفة مدى تطبيق المتطلبات وتحقيق مخرجاتها.
- ◀ لا يكفي عد المستخدمين الذين أقروا بالاطلاع، لأن الإقرار دليل نشر وتوعية لا دليل ممارسة فعلية.
- ◀ تستخدم المؤسسة سجلات الدخول والاستثناءات وتقارير المراجعة ومؤشرات المتابعة لاكتشاف الفجوات وتحسين التنفيذ.
- ◀ **الوظيفة:** كشف الفجوات ودعم التحسين.
- ◀ **المسؤوليات:** مالك السياسة يحدد المتابعة، المنفذ يحفظ الأدلة، الإدارة تراجع النتائج، الفرق تعالج الفجوات.
- ◀ **البروتوكولات والمعايير:** NIST CSF 2.0, NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022.
- ◀ **الأدوات:** سجل إقرار، تقرير مراجعة، سجل استثناءات، مؤشرات متابعة.
- ◀ **المخرج:** تقرير التزام أو سجل فجوات.
- ◀ **مثال:** تتابع الشركة الاستثناءات المنتهية غير المغلقة وسجلات الدخول.
- ◀ زمن الوحدة: 70 دقيقة.
- ◀ اقرأ طلب الاستثناء وتقرير المخالفة، وحدد نطاق القرار وإجراءات الاحتواء والسبب الجذري، ثم اتخذ قراراً تنظيمياً مبرراً.



قياس الالتزام بالسياسة (الشكل)

SLIDE 34 · ELEMENT

قياس الالتزام بالسياسة



الأجهزة والأدوات

- سجل إقرار
- تقرير مراجعة
- سجل استثناءات
- مؤشرات متابعة

البروتوكولات والمعايير

- NIST CSF 2.0
- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022

الوظائف الرئيسية

- كشف الفجوات ودعم التحسين
- مالك السياسة يحدد المتابعة
- المنفذ يحفظ الأدلة
- الإدارة تراجع النتائج
- الفرق تعالج الفجوات

تتابع الشركة الاستثناءات المنتهية غير المغلقة وسجلات الدخول.

قياس الالتزام بالسياسة جمع أدلة مناسبة لمعرفة مدى تطبيق المتطلبات وتحقيق مخرجاتها



- ◀ مخالفة السياسة واقعة لا يلتزم فيها فرد أو عملية بمتطلب وارد في سياسة معتمدة.
- ◀ تصبح المخالفة مدخلاً للتوثيق والتحليل والاحتواء والمعالجة، لا حكماً سريعاً منفصلاً عن الوقائع.
- ◀ في الشركة، ارتبط التقرير INC-2026-058 باستخدام حساب مستخدم مخول من جهاز غير مسجل بعد انتهاء الاستثناء EXC-2026-043.
- ◀ **الوظيفة:** بدء تحليل منظم للواقعة.
- ◀ **المسؤوليات:** المستخدم يبلغ عند الحاجة، المسؤول يوثق الواقعة، المالك يقود المعالجة، الإدارة تتابع الأثر.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5, NIST CSF 2.0, ISO/IEC 27001:2022.
- ◀ **الأدوات:** نموذج بلاغ، سجل مخالفة، سجل أدلة، خطة تصحيحية.
- ◀ **المخرج:** تقرير مخالفة أو حادث داخلي.
- ◀ **مثال:** حظر مشاركة الحسابات ورد في POL-AUP-2026-017.



SLIDE 35 • ELEMENT

مخالفة السياسة



الأجهزة والأدوات

- نموذج بلاغ
- سجل مخالفة
- سجل أدلة
- خطة تصحيحية

الالبروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- NIST CSF 2.0
- ISO/IEC 27001:2022

الوظائف الرئيسية

- بدء تحليل منظم للواقعة
- المستخدم يبلغ عند الحاجة
- المسؤول يوثق الواقعة
- المالك يقود المعالجة
- الإدارة تتابع الأثر

حظر مشاركة الحسابات ورد في POL-AUP-2026-017.

مخالفة السياسة واقعة لا يلتزم فيها فرد أو عملية بمتطلب وارد في سياسة معتمدة.



- ◀ ابدأ بقراءة رقم التقرير INC-2026-058 وتاريخ الإبلاغ 2026-05-26. حدد المرجعين POL-AUP-2026-017 وEXC-2026-043، ثم اقرأ إجراءات الاحتواء المنفذة.
- ◀ انتقل بعد ذلك إلى السبب الجذري والإجراء التصحيحي وتاريخ الاستحقاق 2026-06-23. لا يعد التقرير مغلقاً قبل تحقق معيار الإغلاق المحدد فيه.



(Corrective Action) الإجراء التصحيحي

- الإجراء التصحيحي عمل منظم لمعالجة فجوة أو مخالفة وتحسين الوضع مع تحديد المسؤول والمتابعة.
- لا يقتصر على معالجة العرض الظاهر، مثل إعادة تعيين كلمة المرور، بل يتناول سبب استمرار المشكلة.
- في INC-2026-058 شمل الإجراء تنبيهاً لانتهاك الاستثناء وإيقافاً تلقائياً وتوعية مستهدفة ومراجعة شهرية للسجلات.
- الوظيفة:** تقليل استمرار المشكلة أو تكرارها.
- المسؤوليات:** تحديد الفجوة، تحليل السبب، تعيين المالك، تنفيذ المعالجة، التحقق من الإغلاق.
- البروتوكولات والمعايير:** NIST CSF 2.0, NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022.
- الأدوات:** خطة تصحيحية، سجل إجراءات، سجل متابعة، تقرير مراجعة.
- المخرج:** إجراء موثق بحالة ومالك وتاريخ متابعة.
- مثال:** مسؤول المتابعة إدارة الأمن السيبراني بالتعاون مع تقنية المعلومات.



الإجراء التصحيحي (Corrective Action) (الشكل)

SLIDE 37 · CORRECTIVE ACTION

الإجراء التصحيحي



الأجهزة والأدوات

- خطة تصحيحية
- سجل إجراءات
- سجل متابعة
- تقرير مراجعة

البروتوكولات والمعايير

- NIST CSF 2.0
- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022

الوظائف الرئيسية

- تقليل استمرار المشكلة أو تكرارها
- تحديد الفجوة
- تحليل السبب
- تعيين المالك
- تنفيذ المعالجة

مسؤول المتابعة إدارة الأمن السيبراني بالتعاون مع تقنية المعلومات

الإجراء التصحيحي عمل منظم لمعالجة فجوة أو مخالفة وتحسين الوضع مع تحديد المسؤول والمتابعة



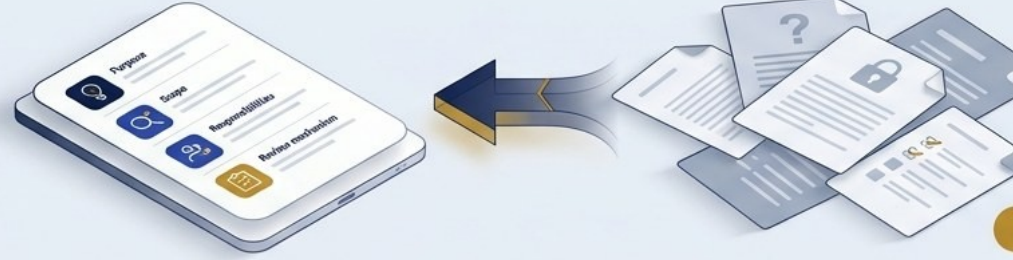
- ◀ أخطاء الصياغة العامة عيوب تجعل السياسة غامضة أو غير قابلة للتطبيق أو غير قابلة للمتابعة.
- ◀ تشمل غياب الغرض أو النطاق أو المسؤوليات أو آلية النشر والمراجعة، وتحويل السياسة إلى قائمة ضوابط بلا سياق تنظيمي.
- ◀ يكشف تحليل هذه الأخطاء الفجوات قبل الاعتماد ويقود إلى نسخة أوضح للمستخدم والمراجع.
- ◀ **الوظيفة:** تحسين جودة الوثيقة قبل نشرها.
- ◀ **المسؤوليات:** الكاتب يحدد العناصر، المراجع يفحص الاتساق، المالك يعتمد النسخة، المستخدم يقدم ملاحظات.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022, ISO/IEC 27002:2022, NIST SP 800-53 Rev. 5.
- ◀ **الأدوات:** قائمة تحقق، نموذج مراجعة، سجل تعليقات.
- ◀ **المخرج:** قائمة فجوات أو نسخة منقحة.
- ◀ **مثال:** سياسة بلا مالك أو تاريخ مراجعة تحتاج إلى تصويب قبل اعتمادها.



أخطاء الصياغة العامة (الشكل)

SLIDE 38 • ELEMENT

أخطاء الصياغة العامة



أخطاء الصياغة العامة عيوب تجعل السياسة غامضة أو غير قابلة للتطبيق أو غير قابلة للمتابعة. تشمل غياب الغرض أو النطاق أو المسؤوليات أو آلية النشر والمراجعة، وتحويل السياسة إلى قائمة ضوابط بلا سياق تنظيمي.

الأجهزة والأدوات

- قائمة تحقق
- نموذج مراجعة
- سجل تعليقات

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022
- ISO/IEC 27002:2022

الوظائف الرئيسية

- تحسين جودة الوثيقة قبل نشرها
- الكاتب يحدد العناصر
- المراجع يفحص الاتساق
- المالك يعتمد النسخة
- المستخدم يقدم ملاحظات

سياسة بلا مالك أو تاريخ مراجعة تحتاج إلى تصويب قبل اعتمادها.

أخطاء الصياغة العامة عيوب تجعل السياسة غامضة أو غير قابلة للتطبيق أو غير قابلة للمتابعة.

مثال محلول على النموذج، تصويب بنود مصادقة غير قابلة للتطبيق

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستفيدين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 خانة لجميع الحسابات.		
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.		
3	انتهى الاستثناء EXC-2026-043، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.		
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقرروا الاطلاع على السياسة فقط.		

يكشف المحرك الإجابة النموذجية تدريجياً بعد أن يصف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- المعطيات: تتضمن ورقة العمل أربعة صفوف.
- يعرض الصف الأول تغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور مع اشتراط 20 خانة.
- يعرض الصف الثالث استمرار الوصول بعد انتهاء EXC-2026-043 واستخدام شخص آخر للحساب.
- المطلوب تحديد التصويب والقاعدة التنظيمية لكل حالة.

الخطوة 1 من 4: تصويب متطلبات المصادقة

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 حانة لجميع الحسابات.	إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل، والإزام تغيير بيانات الاعتماد عند الاشتباه بالاختراق أو عند صدور تنبيه أمني موثق.	الضابط القابل للتطبيق يقلل السلوكيات الالتفافية مثل تدوين كلمات المرور، ويركز على طول مناسب ومصادقة متعددة العوامل والاستجابة لمؤشرات الخطر.
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.		
3	انتهى الاستثناء 043-2026-EXC، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.		
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقرروا الاطلاع على السياسة فقط.		

يكشف المحرك الإجابة النموذجية تدريجياً بعد أن يصف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يدوّن في الصف الأول قرار إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل.
- مصدر القرار هو البند المبالغ فيه في المعطيات.
- القاعدة هي أن الضابط القابل للتطبيق يقلل تدوين كلمات المرور والسلوكيات الالتفافية، ويستجيب لمؤشرات الاشتباه بالاختراق.

الخطوة 2 من 4: معالجة السلوك الالتفافي

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 خانة لجميع الحسابات.	إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل، وإلزام تغيير بيانات الاعتماد عند الاشتباه بالاختراق أو عند صدور تنبيه أمني موثق.	الضابط القابل للتطبيق يقلل السلوكيات الالتفافية مثل تدوين كلمات المرور، ويركز على طول مناسب ومصادقة متعددة العوامل والاستجابة لمؤشرات الخطر.
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.	تسجيل الممارسة كمخاطرة، إزالة البيانات المكتوبة بصورة آمنة، تفعيل دعم لعبارات المرور ومدير كلمات مرور معتمد عند توفره، وتنفيذ توعية تشرح عدم مشاركة أو تدوين بيانات الدخول في أماكن مكشوفة.	السلوك الفعلي دليل على أن صياغة السياسة أو الإجراء لا تحقق الهدف الأمني، ويستلزم معالجة السبب التشغيلي وليس الاكتفاء بالعقوبة.
3	انتهى الاستثناء 043-2026-EXC، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.		
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقرروا الاطلاع على السياسة فقط.		

يكشف المحرك الإجابة النموذجية تدريجياً بعد أن يصف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

◀ يدوّن في الصف الثاني أن كتابة كلمات المرور قرب الأجهزة ممارسة تسجل كمخاطرة.

◀ يتضمن التصويب إزالة البيانات المكتوبة بصورة آمنة، ودعم عبارات المرور ومدير كلمات مرور معتمد عند توفره، وتنفيذ توعية موجهة.

◀ مصدر القرار هو السلوك الفعلي للمستخدمين، والنتائج الجزئية هي معالجة السبب التشغيلي لا الاكتفاء بالعقوبة.

الخطوة 3 من 4: معالجة استثناء منته

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 خانة لجميع الحسابات.	إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل، وإلزام تغيير بيانات الاعتماد عند الاشتباه بالاختراق أو عند صدور تنبيه أمني موثق.	الضابط القابل للتطبيق يقلل السلوكيات الالتفافية مثل تدوين كلمات المرور، ويركز على طول مناسب ومصادقة متعددة العوامل والاستجابة لمؤشرات الخطر.
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.	تسجيل الممارسة كمخاطرة، إزالة البيانات المكتوبة بصورة آمنة، تفعيل دعم لعبارة المرور ومدير كلمات مرور معتمد عند توفره، وتنفيذ توعية تشرح عدم مشاركة أو تدوين بيانات الدخول في أماكن مكشوفة.	السلوك الفعلي دليل على أن صياغة السياسة أو الإجراء لا تحقق الهدف الأمني، ويستلزم معالجة السبب التشغيلي وليس الاكتفاء بالعقوبة.
3	انتهى الاستثناء EXC-2026-043، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.	إيقاف الوصول الاستثنائي فوراً، إعادة تعيين بيانات الاعتماد، مراجعة السجلات، توثيق المخالفة في INC-2026-058، وتفعيل إيقاف تلقائي وتنبيه قبل انتهاء الاستثناء.	الاستثناء يجب أن يكون مؤقتاً ومحدداً بالنطاق والمدة، ولا يجيز مشاركة الحسابات أو الاستمرار بعد انتهاء الموافقة.
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقرروا الاطلاع على السياسة فقط.		

يكشف المحرك الإجابة النموذجية تدريجياً بعد أن يصف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يدون في الصف الثالث إيقاف الوصول الاستثنائي فوراً، وإعادة تعيين بيانات الاعتماد، ومراجعة السجلات، وتوثيق الواقعة في INC-2026-058. مصدر البيانات هو انتهاء EXC-2026-043 في 2026-05-19 واستمرار الوصول من جهاز غير مسجل.
- القاعدة أن الاستثناء محدد بالنطاق والمدة ولا يجيز مشاركة الحسابات أو استمرار الوصول بعد انتهائه.

الخطوة 4 من 4: بناء مؤشرات للالتزام

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 خانة لجميع الحسابات.	إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل، وإلزام تغيير بيانات الاعتماد عند الاشتباه بالاختراق أو عند صدور تنبيه أمني موثق.	الضابط القابل للتطبيق يقلل السلوكيات الالتفافية مثل تدوين كلمات المرور، ويركز على طول مناسب ومصادقة متعددة العوامل والاستجابة لمؤشرات الخطر.
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.	تسجيل الممارسة كمخاطرة، إزالة البيانات المكتوبة بصورة آمنة، تفعيل دعم لعبارة المرور ومدير كلمات مرور معتمد عند توفره، وتنفيذ توعية تشرح عدم مشاركة أو تدوين بيانات الدخول في أماكن مكشوفة.	السلوك الفعلي دليل على أن صياغة السياسة أو الإجراء لا تحقق الهدف الأمني، ويستلزم معالجة السبب التشغيلي وليس الاكتفاء بالعقوبة.
3	انتهى الاستثناء 043-2026-EXC، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.	إيقاف الوصول الاستثنائي فوراً، إعادة تعيين بيانات الاعتماد، مراجعة السجلات، توثيق المخالفة في INC-2026-058، وتفعيل إيقاف تلقائي وتنبيه قبل انتهاء الاستثناء.	الاستثناء يجب أن يكون مؤقتاً ومحددًا بالنطاق والمدة، ولا يحيز مشاركة الحسابات أو الاستمرار بعد انتهاء الموافقة.
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقرروا الاطلاع على السياسة فقط.	إضافة مؤشرات تشمل نسبة تفعيل المصادقة متعددة العوامل، وعدد الاستثناءات المنتهية غير المغلقة، وزمن معالجة بلاغات الحسابات، ونتائج مراجعة سجلات الدخول.	إقرار الاطلاع مؤشر نشر وتوعية، لكنه لا يكفي لقياس الامتثال الفعلي أو فاعلية الضوابط.

يكشف المحرك الإيجابية النموذجية تدريجياً بعد أن يصف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يدوّن في الصف الرابع أن عدد الإقرارات لا يكفي لقياس الالتزام الفعلي.
- يضاف إلى المتابعة تفعيل المصادقة متعددة العوامل، وعدد الاستثناءات المنتهية غير المغلقة، وزمن معالجة بلاغات الحسابات، ونتائج مراجعة سجلات الدخول.
- مصدر القرار هو بند القياس في ورقة العمل، والنتائج نموذج متابعة يرتبط بالممارسة والأدلة.

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

ورقة العمل: ورقة تحليل قابلية تطبيق ضوابط المصادقة

ورقة تحليل قابلية تطبيق ضوابط المصادقة

#	البند أو الحالة المرصودة	التصويب أو القرار المناسب	القاعدة أو المبرر
1	يلزم المستخدم بتغيير كلمة المرور كل 7 أيام ومنع إعادة استخدام آخر 24 كلمة مرور، مع اشتراط طول لا يقل عن 20 حانة لجميع الحسابات.	إلغاء التغيير الدوري قصير الأجل غير المبني على مؤشر خطر، واعتماد عبارة مرور طويلة مناسبة مع المصادقة متعددة العوامل، وإلزام تغيير بيانات الاعتماد عند الاشتباه بالاختراق أو عند صدور تنبيه أمني موثق.	الضابط القابل للتطبيق يقلل السلوكيات الالتفافية مثل تدوين كلمات المرور، ويركز على طول مناسب ومصادقة متعددة العوامل والاستجابة لمؤشرات الخطر.
2	كتب بعض المستخدمين كلمات المرور على أوراق قريبة من أجهزة العمل لأن متطلبات التغيير المتكرر صعبة التذكر.	تسجيل الممارسة كمخاطرة، إزالة البيانات المكتوبة بصورة آمنة، تفعيل دعم لعبارة المرور ومدير كلمات مرور معتمد عند توفره، وتنفيذ توعية تشرح عدم مشاركة أو تدوين بيانات الدخول في أماكن مكشوفة.	السلوك الفعلي دليل على أن صياغة السياسة أو الإجراء لا تحقق الهدف الأمني، ويستلزم معالجة السبب التشغيلي وليس الاكتفاء بالعقوبة.
3	انتهى الاستثناء 2026-043-EXC، لكن استمر المستخدم في الوصول من جهاز غير مسجل واستخدم شخص آخر الحساب لمتابعة الطلبات.	إيقاف الوصول الاستثنائي فوراً، إعادة تعيين بيانات الاعتماد، مراجعة السجلات، توثيق المخالفة في INC-2026-058، وتفعيل إيقاف تلقائي وتنبيه قبل انتهاء الاستثناء.	الاستثناء يجب أن يكون مؤقتاً ومحدداً بالنطاق والمدة، ولا يحيز مشاركة الحسابات أو الاستمرار بعد انتهاء الموافقة.
4	تقيس الإدارة الالتزام بعدد المستخدمين الذين أقرروا الاطلاع على السياسة فقط.	إضافة مؤشرات تشمل نسبة تفعيل المصادقة متعددة العوامل، وعدد الاستثناءات المنتهية غير المغلقة، وزمن معالجة بلاغات الحسابات، ونتائج مراجعة سجلات الدخول.	إقرار الاطلاع مؤشر نشر وتوعية، لكنه لا يكفي لقياس الامتثال الفعلي أو فاعلية الضوابط.

يكشف المحرك الإيجابية النموذجية تدريجياً بعد أن يصف الطالب كل حالة ويقترح تصويماً قابلاً للتنفيذ.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

الناتج: اكتملت ورقة العمل بأربعة قرارات مترابطة.

عالجت متطلبات المصادقة غير القابلة للتطبيق، والسلوك الالتفافي، والاستثناء المنتهي، وقياس الالتزام.

يتحقق الطالب من أن كل صف يربط الحالة المرصودة بتصويب محدد وقاعدة تنظيمية، وأن قياس الالتزام يستند إلى أدلة ممارسة فعلية لا إلى الإقرار وحده.

زمن الوحدة: 70 دقيقة.

اتبع المثال المحلول على النموذج، وحل بنداً عاماً، وصغ بديلاً قابلاً للتنفيذ، ثم راجع مفاهيم الفصل واختبار الوحدة.



مشاركة الموظفين في تطوير السياسة



- ◀ مشاركة الموظفين في تطوير السياسة تعني الاستفادة من مدخلات الأدوار المتأثرة بالوثيقة عند الصياغة أو المراجعة.
- ◀ تكشف هذه المشاركة احتياجات العمل والمخاطر الواقعية، مثل أثر متطلبات المصادقة غير القابلة للتطبيق.
- ◀ لكنها لا تنقل مسؤولية الاعتماد إلى المشاركين، لأن الاعتماد والملكية يظلان من اختصاص الجهة المخولة.
- ◀ **الوظيفة:** رفع قابلية التطبيق وكشف الاحتياجات الواقعية.
- ◀ **المسؤوليات:** الموظفون يقدمون المدخلات، مالك السياسة ينسق، الإدارة تعتمد، الفرق تنفذ.
- ◀ **البروتوكولات والمعايير:** NIST CSF 2.0, NIST SP 800-53 Rev. 5, ISO/IEC 27001:2022.
- ◀ **الأدوات:** ورشة مراجعة، نموذج ملاحظات، مراجعة أقران، سجل قرار.
- ◀ **المخرج:** ملاحظات موثقة أو قرار تعديل.
- ◀ **مثال:** تسهم ملاحظات فريق التشغيل في تحسين بنود الوصول عن بعد.



مشاركة الموظفين في تطوير السياسة (الشكل)

SLIDE 44 · ELEMENT

مشاركة الموظفين في تطوير السياسة



الأجهزة والأدوات

- ورشة مراجعة
- نموذج ملاحظات
- مراجعة أقران
- سجل قرار

البروتوكولات والمعايير

- NIST CSF 2.0
- NIST SP 800-53 Rev. 5
- ISO/IEC 27001:2022

الوظائف الرئيسية

- رفع قابلية التطبيق وكشف الاحتياجات الواقعية
- الموظفون يقدمون المدخلات
- مالك السياسة ينسق
- الإدارة تعتمد
- الفرق تنفذ

تسهم ملاحظات فريق التشغيل في تحسين بنود الوصول عن بعد

مشاركة الموظفين في تطوير السياسة تعني الاستفادة من مدخلات الأدوار المتأثرة بالوثيقة عند الصياغة أو المراجعة

حالة محلة، استخدام حساب بعد انتهاء الاستثناء



◀ **المعطيات:** انتهى EXC-2026-043 في 2026-05-19. وفي 2026-05-26 سجلت الشركة محاولة دخول من جهاز غير مسجل باستخدام حساب مستخدم مخول، وأظهر الفحص الأولي استخدام شخص آخر للحساب.

◀ خطوات التحليل:

1. ربط الواقعة بحظر مشاركة الحسابات في POL-AUP-2026-017.
 2. تحديد الأصل المتأثر، وهو حساب المستخدم وسجل طلبات المستخدمين.
 3. تنفيذ الاحتواء، بتعطيل الجلسات وإعادة تعيين كلمة المرور وإلغاء الوصول المنتهي.
 4. تحليل السبب الجذري وتعيين مسؤول المتابعة.
 5. توثيق الإجراء التصحيحي وتاريخ استحقاقه 2026-06-23.
- ◀ **النتائج:** تقرير INC-2026-058 قيد المتابعة حتى تحقق معيار الإغلاق.



نشاط تطبيقي، تحليل بند سياسة

السيناريو

اقرأ البند الآتي: "تنطبق متطلبات حماية الحسابات على الجميع دائماً".
ثم أجب في ملفك الدراسي:
عند الانتهاء، قارن إجابتك بالنموذج في الشريحة التالية.

المطلوب

١. ما عنصر السياسة الناقص في هذه الصياغة؟
٢. ما الفئات التي ينبغي تحديدها في نطاق سياسة الشركة؟
٣. ما المسؤوليات التي تختلف بين المستخدم وإدارة تقنية المعلومات؟
٤. كيف يمكن قياس الالتزام بحماية الحسابات؟
٥. اكتب صياغة بديلة من سطرين تتضمن نطاقاً ومسؤولية قابلة للتنفيذ.



- ◀ الصياغة الأصلية ناقصة لأنها لا تحدد النطاق أو الفئات أو المسؤوليات.
- ◀ تشمل سياسة الشركة الموظفين والمتعاقدين والمتدربين والمستفيدين المصرح لهم باستخدام الخدمات المحددة.
- ◀ يلتزم المستخدم بحماية حسابه والإبلاغ عن الاشتباه، بينما تدير تقنية المعلومات الحسابات والدعم الفني.
- ◀ تقاس الممارسة بسجلات الدخول والاستثناءات والمراجعات، لا بالإقرار فقط.
- ◀ صياغة بديلة: «تنطبق متطلبات حماية الحسابات على المستخدمين المصرح لهم في بوابة الخدمات التعليمية.
- ◀ يلتزم المستخدم بعدم مشاركة بيانات الاعتماد، وتدير تقنية المعلومات الحسابات وسجل الدعم».

مرحلة المشروع التراكمي الأولى، نطاق المؤسسة وهيكل السياسة

- ▶ يعمل فريق من 3 إلى 4 طلاب مدة 40 دقيقة على بداية مشروع «حزمة سياسة وامثال وأخلاقيات لمؤسسة رقمية سعودية».
- ▶ اخترتوا مؤسسة افتراضية بوصف نشاطها فقط.
- ▶ سلموا صفحة واحدة تتضمن نوع المؤسسة، ونطاقها، وجرداً أولياً من أربعة أصول معلوماتية، وهيكل سياسة مقترحاً بعناوينه.
- ▶ احفظوا المخرج لتطويره في المراحل اللاحقة.

الحد الأدنى	المطلوب
نشاطها، مستخدموها، وخدماتها الرقمية	وصف المؤسسة والنطاق
أربعة أصول معلوماتية أولية	جرد الأصول
الغرض، النطاق، الأدوار، الالتزام، المراجعة	هيكل السياسة



الهدف الثاني: تختلف السياسات بحسب الغرض والنطاق والفئات، مثل سياسة الاستخدام المقبول وسياسة التحكم في الوصول.



الهدف الأول: السياسة الأمنية قواعد موثقة توجه حماية المعلومات واستخدامها ضمن إطار الحوكمة.



الهدف الرابع: تصاغ بنود الاستخدام المقبول بلغة محددة تربط السلوك المطلوب بالإبلاغ والمساءلة.



الهدف الثالث: تتكون السياسة القابلة للتحليل من غرض ونطاق ومالك وأدوار والتزام واستثناءات ومراجعة.



الهدف الخامس: تطور السياسة عبر جمع المتطلبات والاعتماد والنشر والمراقبة والمراجعة والتحديث، وتعالج المخالفات بإجراءات تصحيحية عند ظهور فجوة.



1. International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection, Information security management systems, Requirements (Edition 3).
2. International Organization for Standardization & International Electrotechnical Commission. (2022). ISO/IEC 27002:2022: Information security, cybersecurity and privacy protection, Information security controls (Edition 3).
3. Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST Cybersecurity White Paper 29).
4. Joint Task Force. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev. 5).
5. Nieves, M., Dempsey, K., & Pillitteri, V. (2017). An Introduction to Information Security (NIST SP 800-12 Rev. 1).

مصادر إثرائية اختيارية خارج وقت التعلم الإلزامي ◀

1. Stallings, W. (2018). Effective Cybersecurity: A Guide to Using Best Practices and Standards (1st ed.). Addison-Wesley Professional.
2. Whitman, M. E., & Mattord, H. J. (2022). Principles of Information Security (7th ed.). Cengage Learning.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان